**Security infrastructure design documentation**
**Artisan Widgets Ltd.**
**Prepared for: Security consultant Assignment**
**Date: 2023**

**Introduction and purpose**
This security infrastructure Design Document outlines a comprehensive architecture for Artisan Widgets Ltd., a small but growing online retailer specializing in artisanal, hand-crafted widgets. The company currently employs 50 staff members in a single office and operates an external e-commerce website that processes customer orders and payment information.
As a security consultant, the objective is to design and recommend security measures that protect customer data, employee systems, and business operations while meeting the following organizational requirements:

- Secure external website for browsing and purchasing widgets
- secure internal intranet website for employees
- secure remote access for engineering employees (including command-line access)
- reasonable basic firewall rules
- wireless coverage in the office
- reasonable secure laptop configurations

Special emphasis is placed on protecting customer payment data and personal information due to the retail nature of the business. The design follows the principles of defense-in-depth, least privilege, and zero-trust where applicable, while remaining practical and cost-effective for a small organization.

***Key assets to protect:***

- Customer personal and payment data (subject to PCI DSS)
- Employee credentials and internal business database, company intellectual property and financial records

***Primary threats***

- External web attacks (SQL injection, XSS, DDoS)
- malware infection via lost or compromised laptops
- unauthorized remote access. Data breaches leading to privacy violations

**Security goals ranking:**

- ***Confidentiality:*** High
- ***Integrity:*** High
- ***Availability:*** Medium
- ***Auditability:*** High
- ***Non-Repudiation:*** Medium

## Authentication System

A centralized and access management solution is recommended as the foundation of all authentication.
***Recommended solution***: Microsoft Entra ID (Azure AD) or Okta as Identity Provider (IdP).
***Key features***:

- Multi-Factor Authentication (MFA) enforced for all users (employees, administrators, and remote access)
- Role-Based Access Control (RBAC)
- Single Sign-On (SSO) for both internal and external systems

- Password policy: Minimum 14 characters, complexity requirements, 90-day expiration, and account lockout after 5 failed attempts
- Support for passwordless authentication (passkeys) in the future

All systems (intranet, remote access, laptops) will integrate with this central IdP to ensure consistent and auditable authentication.

## External Website Security

The public e-commerce website must be hardened against common web threats while providing a smooth shopping experience.

***Recommended Measures:***

- Enforcement of HTTPS only using TLS 1.3 with a valid certificate (issued via Let's Encrypt or a commercial CA)
- Web Application Firewall (WAF) – Cloudflare WAF or AWS WAF to protect against OWASP Top 10 vulnerabilities (SQL injection, XSS, CSRF, etc.)
- Payment processing via a PCI DSS – compliant third-party provider (e.g., Stripe or PayPal) using tokenization. The company will not store full credit card details (reducing PCI DSS scope to SAQ A or A-EP)
- regular vulnerability scanning and annual penetration testing
- secure coding practices: Input sanitization, parameterized queries, and Content Security Policy (CSP)
- DDoS protection provided by the WAF or CDN

## Internal Website Security (Intranet)

The internal intranet provides employees with access to company resources and must remain isolated from the public internet.

***Recommended Measures:***

- Hosted on an internal server or private cloud environment, accessible only after successful authentication via the central IdP with MFA
- Role-based access control (e.g., HR views only personnel data, Finance views accounting data)
- session timeout after 15 minutes of inactivity
- Protected by a reverse proxy with WAF rules
- All traffic between client and intranet encrypted with TLS

## Remote Access Solution

Engineering employees require secure command-line access to their workstations from remote locations.

***Recommended Solution***: Zero Trust Network Access (ZTNA) – preferred over traditional VPN.

***Options:***

- Primary: Cloudflare Access, Tailscale, or Zscaler Private Access
- Alternative: WireGuard VPN with MFA and device posture checks

***Key controls:***

- Continuous verification of user identity, device health, and context before granting access
- Granular access: Engineers can only reach their assigned workstations via SSH (port 22) or RDP through the ZTNA tunnel
- No direct exposure of SSH/RDP ports to the internet
- Device compliance checks (antivirus status, OS updates, disk encryption) before access is allowed

## Firewall and Basic Rules Recommendations

A Next-Generation Firewall (NGFW) will be deployed at the network perimeter.

***Recommended Hardware/Software:*** pfsense, OPNsense, or Fortinet 30F/40F (cost-effective for small offices).
***Default Policy***: Deny All (implicitly deny).
***Basic Firewall rules:***
***Inbound Traffic:***

- Allow TCP 443 (HTTPS) only to the external web server in the DMZ zone
- Block all other inbound traffic by default (including known malicious ports)

***DMZ Configuration:*** External web server placed in a dedicated DMZ segment, isolated from internal network.
***Logging:*** All denied connections logged and forwarded to a central monitoring system with email alerts for suspicious activity.
Additional GEO-IP blocking for high-risk countries (if no business need)

## Wireless Security

Wireless coverage is required throughout the small office.
***Recommended Configuration:***

- WPA-3 Enterprise (preferred) or WPA-3 Personal with a strong pre-shared key
- Separate SSIDs:
  - Corporate-SSID: Access to corporate network and internal resources (802.1X authentication via RADIUS integrated with IdP)
  - Guest-SSID: Internet-only access with client isolation enabled
- Client isolation enabled on both networks
- Regular firmware updates on access points
- MAC address filtering as an additional (but not primary) control

## VLAN Configuration Recommendations

Network segmentation using VLANs will limit lateral movement in case of compromise.
***Proposed VLANs:***

- VLAN 10 – Corporate (employee laptops and desktops)
- VLAN 20 – Guest (visitor devices)
- VLAN 30 – DMZ (external web server)
- VLAN 40 – Servers (internal application and file servers)
- VLAN 50 – IoT/Printers (if applicable)

***Implementation:***

- Dynamic VLAN assignment based on 802.1X authentication
- Inter-VLAN routing controlled by Access Control Lists (ACLs) on the Layer 3 switch or firewall
- No unnecessary communication allowed between VLANs (e.g., Guest VLAN cannot reach Corporate or Server VLANs)

## Laptop Security Configuration

Laptops are high-risk devices due to mobility and potential for loss or theft.
***Recommended Controls:***

- Full Disk Encryption: BitLocker (Windows) or FileVault (macOS) with centralized key escrow
- Mobile Device Management (MDM): Microsoft Intune or equivalent to enforce policies centrally
- Endpoint Detection and Response (EDR): Microsoft Defender for Endpoint (included with many business plans)
- Security policies:
  - Automatic screen lock after 5 minutes of inactivity
  - Automatic OS and application updates

    - USB device restrictions (block unauthorized storage devices)
    - Remote wipe capability for lost/stolen devices
- Mandatory antivirus/EDR with real-time protection and behavioral analysis

## Application Policy Recommendations

- All internally developed applications must follow OWASP Secure Coding Practices
- Automated security testing (SAST/DAST) integrated into the CI/CD pipeline
- Development and testing environments must use anonymized or synthetic data (never real customer payment data)
- Application whitelisting on employee laptops
- Regular patching of all third-party applications and libraries.

## Security and Privacy Policy Recommendations

***Privacy Policy (publicly displayed on the website):***

- Clear explanation of what customer data is collected and how it is used
- Cookie policy with consent management
- Statement that customer data is not sold to third parties without explicit consent
- Opt-out options for marketing communications
- Contact information for privacy inquiries

***Security Policy (internal):***

- Mandatory annual security awareness training for all employees (including phishing simulations)
- Incident response plan with defined roles and 24-hour reporting requirement
- Clear acceptable use policy for company devices and networks
- Commitment to compliance with PCI DSS and applicable data protection regulations (GDPR/CCPA principles)

***Recommendation***: Obtain a third-party privacy seal (e.g., TRUSTe or equivalent) to build customer trust.

## Intrusion Detection and Prevention for Systems Containing Customer Data

***Recommended Solution:***

- Host-based Wazuh (open-source) for file integrity monitoring, log analysis, and active response
- Network-based: Suricata or Snort as Intrusion Prevention System (IPS) integrated with the firewall
- Centralized logging and alerting to a SIEM-like dashboard (Wazuh + Elastic Stack or built-in tools)
- Real-time alerts for suspicious activity on systems handling customer data (Cardholder Data Environment)
- Regular vulnerability scanning and quarterly penetration testing of critical systems

This layered approach provides both detection and automated prevention capabilities

## Summary and Implementation Recommendations

The proposed security infrastructure provides robust protection for Artisan Widgets Ltd. while remaining manageable for a small team. This design addresses all 11 security requirements, achieving PCI DSS compliance scope reduction through payment tokenization, zero-trust remote access for engineering employees, and a layered defence-in-depth architecture protecting customer payment data at every level. It significantly reduces risk to customer data, supports secure remote work for engineers, and establishes a scalable foundation for future growth.

***Next Steps:***

1. Conduct a formal risk assessment and define PCI DSS scope
2. Implement MFA and central identity management first (quick win)

3. Deploy ZTNA for remote access and NGFW
4. Roll out laptop encryption and MDM
5. Provide security awareness training to all employees
6. Schedule regular audits and penetration tests

This design balances security, usability, and cost-effectiveness. It can be implemented using a mix of cloud services, open-source tools, and affordable commercial solutions.